

ANALISI E STUDIO DELLE VULNERABILITA

Parte facoltativa – approfondimento tecnico

Scopo

Questo documento approfondisce le vulnerabilità più significative rilevate durante la pratica, collegando evidenza Nessus, rischio e remediation.

VNC – credenziale debole

Plugin 61708 – Critical – CVSS 10.0. Nessus ha rilevato il servizio VNC sulla porta 5900/tcp e ha confermato l'utilizzo della password 'password'.

Metasploitable scansioni completa / Plugin #201352

Configure Audit Trail Launch Report Export

Hosts 1 Vulnerabilities 70 Remediations 2 Notes 2 History 3

CRITICAL Canonical Ubuntu Linux SEoL (8.04.x)

Description
According to its version, Canonical Ubuntu Linux is 8.04.x. It is, therefore, no longer maintained by its vendor or provider.

Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.

Solution
Upgrade to a version of Canonical Ubuntu Linux that is currently supported.

See Also
<http://www.nessus.org/u/73bdb2d2e>

Output

```
OS                : Ubuntu Linux 8.04
Security End of Life : May 8, 2013
Time since Security End of Life (Est.) : ~ 13 years
```

To see debug logs, please visit individual host

Port 4 Hosts

80 / tcp / www 192.168.60.101

Plugin Details

Severity: Critical
ID: 201352
Version: 1.2
Type: combined
Family: General
Published: July 3, 2024
Modified: March 26, 2025

Risk Information

Risk Factor: Critical
CVSS v3.0 Base Score: 10.0
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/CHIR:H/AH
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

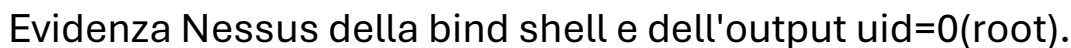
Vulnerability Information

CPE: cpe:/o:canonical:ubuntu_linux
Unsupported by vendor: true

Evidenza Nessus del problema VNC.

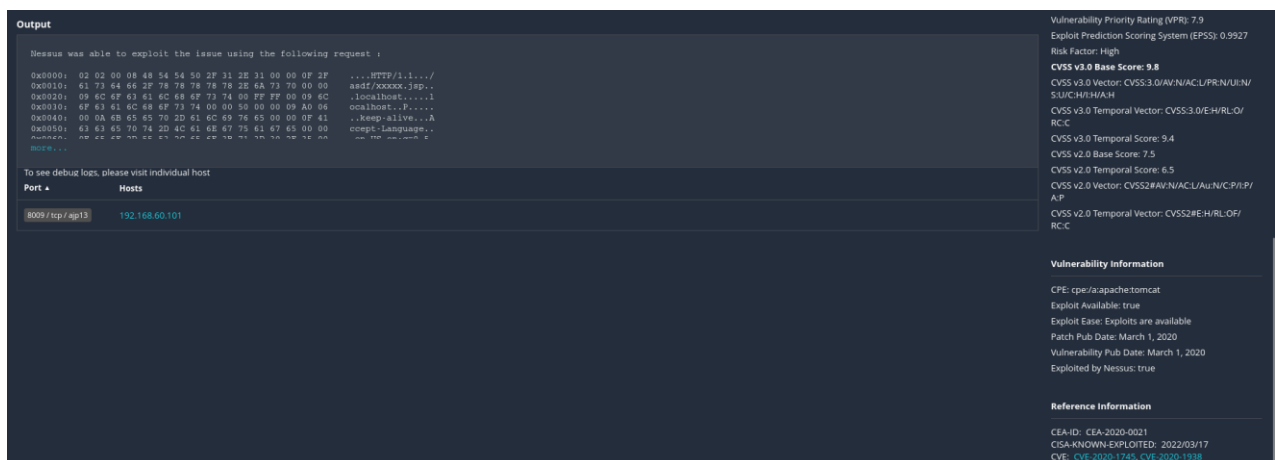
Rischio un attaccante remoto potrebbe autenticarsi al servizio e ottenere controllo della sessione grafica. Remediation: utilizzare credenziali robuste, eliminare password predefinite e limitare l'esposizione del servizio.

Plugin 51988 – Critical – CVSS 9.8. Il servizio sulla porta 1524/tcp ha consentito a Nessus di eseguire 'id', restituendo uid=0(root).



Remediation: rimuovere/disabilitare il servizio, verificare l'integrità del sistema e, se necessario, reinstallare il sistema in caso di compromissione.

Plugin 20007 – Critical – CVSS 9.8. Sono stati rilevati protocolli SSL legacy e cipher deboli. Devono essere disabilitati SSLv2 e SSLv3; deve essere utilizzato TLS 1.2 o superiore. **Apache Tomcat / Ghostcat**



Tomcat 5.5 fuori supporto.

The screenshot shows a vulnerability scanner interface with a dark theme. The main section is titled 'Bind Shell Backdoor Detection' and is marked as 'CRITICAL'. It includes a description, a solution, and an output section. The output shows a successful execution of the 'id' command, resulting in root access. To the right, there is a 'Plugin Details' sidebar with fields for Severity, ID, Version, Type, Family, Published, and Modified. Below this is a 'Risk Information' section with a risk factor and CVSS scores.

Plugin Details	
Severity:	Critical
ID:	51988
Version:	1.10
Type:	remote
Family:	Backdoors
Published:	February 15, 2011
Modified:	April 11, 2022

Risk Information	
Risk Factor:	Critical
CVSS v3.0 Base Score:	9.8
CVSS v3.0 Vector:	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CVSS v2.0 Base Score:	10.0
CVSS v2.0 Vector:	CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Vulnerabilità AJP Request Injection (Ghostcat).

Il Tomcat 5.5 rilevato è fuori supporto. La vulnerabilità Ghostcat riguarda il connettore AJP e può consentire lettura di file e, in determinate condizioni, esecuzione di codice. La remediation consiste nell'aggiornamento a una versione supportata e nella messa in sicurezza/disabilitazione di AJP quando non necessario.

Evidenze della remediation VNC

```
msfadmin@metasploitable:~$ sudo kill -HUP 4436
msfadmin@metasploitable:~$ sudo netstat -tulpn | grep 1524
msfadmin@metasploitable:~$
```

Processo Xtightvnc in esecuzione.

```
msfadmin@metasploitable:~$ sudo -u msfadmin /usr/bin/vncpasswd /home/msfadmin/.vnc/passwd
Password:
Verify:
Would you like to enter a view-only password (y/n)? n
Cannot write password file /home/msfadmin/.vnc/passwd
msfadmin@metasploitable:~$
```

Controllo del file di password VNC.

```
msfadmin@metasploitable:~$ sudo ls -la /home/msfadmin/.vnc/
total 68
drwx----- 2 root      root      4096 2026-10-03 10:54 .
drwxr-xr-x  9 msfadmin msfadmin  4096 2026-10-03 10:54 ..
-rw-r--r--  1 root      root     34723 2026-10-03 17:40 metasploitable:0.log
-rw-r--r--  1 root      root        5 2026-10-03 10:54 metasploitable:0.pid
-rw-r--r--  1 root      root     8114 2026-10-03 10:23 metasploitable:1.log
-rw-r--r--  1 root      root        5 2026-10-03 10:23 metasploitable:1.pid
-rw-----  1 root      root        8 2026-10-02 16:38 passwd
-rwxr-xr-x  1 root      root     151 2026-10-02 16:38 xstartup
msfadmin@metasploitable:~$
```

Riavvio di xinetd dopo la modifica.

Hosts 1 Vulnerabilities 58 Remediations 3 Notes 1 History 4								
Filter	Search Vulnerabilities						58 Vulnerabilities	
Sev	CVSS	VPR	EPSS	Name	Family	Count		
☐ CRITICAL	10.0 *	7.9	0.8353	UnrealIRCd Backdoor Detection	Backdoors	1	☐	☐
☐ CRITICAL	10.0 *	5.8	0.7072	Debian OpenSSH/OpenSSL Package Random Number Generator Weakness	Gain a shell remotely	1	☐	☐
☐ CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1	☐	☐
☐ MIXED	...	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4	☐	☐
☐ HIGH	7.5	4.9	0.3693	Samba Badlock Vulnerability	General	1	☐	☐
☐ HIGH	7.5 *	4.9	0.119	rlogin Service Detection	Service detection	1	☐	☐
☐ HIGH	7.5 *	4.9	0.119	rsh Service Detection	Service detection	1	☐	☐
☐ HIGH	7.5			NFS Shares World Readable	RPC	1	☐	☐
☐ MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5	☐	☐
☐ MEDIUM	6.5			Unencrypted Telnet Server	Misc.	1	☐	☐
☐ MIXED	...	...	...	SSH (Multiple Issues)	Misc.	6	☐	☐
☐ MIXED	...	...	...	HTTP (Multiple Issues)	Web Servers	5	☐	☐

Scan Details

Policy: Basic Network Scan
Status: Completed
Severity Base: CVSS V3.0
Scanner: Local Scanner
Start: Today at 9:30 AM
End: Today at 9:50 AM
Elapsed: 20 minutes

Vulnerabilities

● Critical
● High
● Medium
● Low
● Info

Verifica della porta 5900/tcp.

Metodo di verifica

Per ogni remediation si deve identificare il servizio, applicare la correzione, riavviare il servizio interessato, verificare localmente processi e porte e quindi ripetere la scansione Nessus.

Conclusione

L'analisi mostra che le vulnerabilità più gravi sono associate a software obsoleto, servizi legacy e configurazioni insicure. Il laboratorio dimostra l'importanza di validare ogni remediation con una nuova scansione.